Zscaler Zero Trust Automation (EDU-270)

Introduction to APIs

An API, or Application Programming Interface, is a set of rules and protocols that allow software programs to communicate with each other. An API is made up of endpoints. Endpoints are the different interaction points between systems providing specific sets of data.

RESTful API:

A RESTful API is an API web service that uses standard HTTP methods (e.g. GET, POST, PUT, DELETE) to interact with resources identified by URLs, allowing different software systems to communicate over the internet in a stateless and consistent manner.

How APIs work:

APIs work by sharing data between applications, systems, and devices. This happens through a request and response cycle. The request is sent to the API, which retrieves the data and returns it to the user. Here's a high-level overview of how that process works.

API client:
APIs work by sharing data between applications, systems, and devices. The cycle is completed when a request is sent to the API, which retrieves the data, and a response is received. API requests may also be triggered by external events, such as a notification from another application.

API request:
An API request will look and behave differently depending on the type of API, but it will typically include the following components:

Endpoint:
An API endpoint is a dedicated URL that provides access to a specific resource. For instance, the /articles endpoint in a blogging app would include the logic for processing all requests that are related to articles.

Method:
The request's method indicates the type of operation the client would like to perform on a given resource. REST APIs are accessible through standard HTTP methods, which perform common actions like retrieving, creating, updating, and deleting data.

Parameters:
Parameters are the variables that are passed to an API endpoint to provide specific instructions for the API to process. These parameters can be included in the API request as part of the URL, in the query string, or in the request body. For example, the /articles endpoint of a blogging API might accept a “topic” parameter, which it would use to access and return articles on a specific topic.

120 Holger Way
San Jose, CA 95134
+1 408.533.0288
zscaler.com

Zscaler APIs

ZIA API

Zscaler Internet Access (ZIA) provides you programmatic access and control and configuration of the Zero Trust Exchange. Zscaler provides secured access to cloud service API, Sandbox Submission API, and 3rd-Party App Governance API using different authentication schemes.

ZDX API

Zscaler Digital Experience (ZDX) APIs enable you to pull information about the accesses, the health of applications, and provide that holistic approach to monitor core quality. For example, with Zoom, integrate with ServiceNow from your help desk ticketing, and look at the endpoint to understand issues on the endpoint as well.

ZPA API

The Zscaler Private Access (ZPA) API offers programmatic access to manage a variety of ZPA features. This API enables developers and administrators to automate and control various aspects of their ZPA deployment, ensuring streamlined and efficient management.

Zscaler Cloud/ Branch connector APIs

The Zscaler Cloud & Branch Connector API provides programmatic access to manage various features of the Zscaler Cloud & Branch Connector. This enables developers and administrators to automate and control different aspects of their deployment, ensuring efficient management and integration.

ZIdentity

ZIdentity is a unified identity service for Zscaler that centralizes and simplifies identity management, user authentication, and entitlement assignment for users to Zscaler services, such as Zscaler Internet Access (ZIA), Zscaler Private Access (ZPA), Zscaler Digital Experience (ZDX), etc. The services are managed through individual Zscaler admin portals (e.g., ZIA Admin Portal). If you have subscribed to more than one Zscaler service or just one service for multiple organizations, you must access these portals using different login credentials.

With ZIdentity, a single authentication into Zscaler allows users to seamlessly access Zscaler services used by their organization, without worrying about remembering or managing multiple passwords.

ZIdentity supports multi-factor authentication (MFA) for enhanced security, and it is required by default. Zscaler strongly recommends enabling MFA. You can authenticate users with a password, password and a second factor such as SMS one-time password (OTP), email OTP, Google Authenticator (TOTP), and fast identity online (FIDO) authentication.

ZIdentity has the following key features and benefits:

- Seamless access to all the subscribed Zscaler services with a single set of credentials
- Secured authentication of users using MFA
- Easy management and control of admin roles and access to Zscaler services

Zscaler, Inc. (HQ)
120 Holger Way
San Jose, CA 95134
+1 408.533.0288
zscaler.com

- Easy creation and management of user accounts in the ZIdentity admin portal
- Automatic synchronization of users with identity providers through SAML just-in-time (JIT) provisioning or SCIM provisioning
- Limited administrator access based on source IP address to ensure that admins access the system from authorized locations
- Quick access to audit reports evaluating configuration changes in ZIdentity.

Zscaler OneAPI

Zscaler OneAPI provides programmatic access to different Zscaler services with consistency in API design and experience across all products, reliability, and high performance of the APIs. They allow for a centralized management of key components and features of APIs, including but not limited to API authentication, tenant access policies and management, rate limiting, caching, API lifecycle management, etc., thereby providing a consistent and uniform cross-product API experience and offering enhanced support for automation and integration with external services.

Before OneAPI : Zscaler Automation Framework:

One of the major challenges faced by API clients before the implementation of OneAPI was the complexity involved in switching between different products. Each time a user needed to switch, they had to go through the entire process of registration, authorization, token request, and token grant.

During automation, this meant that users had to remember and manage multiple different endpoints, which was not only cumbersome but also prone to errors.

The implementation of OneAPI is crucial in addressing these challenges. It simplifies the process, avoids confusion, and provides a significantly better user experience by unifying the API interaction under a single, consistent framework.

Zscaler Zero Trust Automation:

The goal of Zscaler Platform Automation is to empower enterprises and partners to rapidly and effectively adopt a Zero Trust Architecture.

Key Benefits Include:

- Improved Security Posture: By enforcing strict access controls and continuous verification, Zero Trust Automation significantly enhances the security posture of an organization.
- Streamlined Processes: Automation simplifies and accelerates security processes, reducing the complexity and effort required for manual configurations.
- Better ROI by Automating Security Tasks: Automating routine security tasks results in cost savings and maximizes the return on investment by freeing up resources for more strategic initiatives.
- Reduced Human Error: Automation minimizes the risk of human error, which is often a significant factor in security breaches and misconfigurations.
- Faster Threat Response: Automated systems can detect and respond to threats more quickly than manual processes, thereby reducing the potential impact of security incidents.

Zscaler, Inc. (HQ)
120 Holger Way
San Jose, CA 95134
+1 408.533.0288
zscaler.com

- Enhanced Visibility and Control: With Zscaler OneAPI, organizations achieve better visibility and control over their environments, ensuring comprehensive monitoring and management of their security landscape.

OneAPI: The Gateway Platform

OneAPI simplifies API integration by providing a single-entry point for accessing multiple APIs. It enhances security and performance with centralized management and advanced monitoring capabilities.

Key Benefits of Gateway Platform

Globally Distributed Platform

Low Latency: By distributing API gateways across various global regions, the platform ensures that API requests are processed quickly, reducing the time it takes for data to travel between the client and server.

Geographic Aware

Requests Routed to Closest Region: The platform intelligently routes API requests to the nearest regional gateway, optimizing performance and reducing latency for end-users.

Zscaler Cloud Agnostic

Single Endpoint for All Product Clouds: Users can access multiple Zscaler services through a single, unified endpoint, simplifying API integrations and reducing the need to manage multiple URLs or endpoints.

Authenticate Once

ZIdentity API Client Credentials (OAuth): By utilizing OAuth for authentication, users only need to authenticate once to gain access to multiple services. This simplifies the authentication process, enhances security, and provides a seamless user experience.

Components of OneAPI

Access Tokens

An access token is a secure, time-sensitive credential used by applications to authenticate and authorize API requests, ensuring that only authorized users can access specific resources and perform actions.

API Resources

API resources are specific endpoints that provide access to various identity management functionalities, enabling integration and automation of security-related tasks.

API Client

An API client is an application that interacts with Zscaler's APIs, facilitating secure communication and integration with ZIdentity.

Zscaler, Inc. (HQ)
120 Holger Way
San Jose, CA 95134
+1 408.533.0288
zscaler.com

Zscaler API Architecture and Access

Zscaler APIs provide a secure and scalable approach to programmatically manage and configure Zscaler services, enabling seamless policy enforcement, configuration management, and comprehensive logging through an authenticated and documented API gateway.

Central Authority Level

API Gateway: The central hub for applying policies and retrieving data.
Authentication: The gateway authenticates with the Central Authority, which may include the Admin Portal.
Browser and Programmatic Access: Activities done in the browser are driven by APIs, which can also be used programmatically for various controls.

API Capabilities

Policy Management:

- Make policy changes and configurations programmatically.
- Update application segments and manage access policies.

Log Management:

- Stream logs for monitoring and analysis.

Configuration Management:

- Handle SCIM (System for Cross-domain Identity Management) and IdP (Identity Provider) configurations.
- Manage custom service edges, trusted networks, and connector groups.

Authentication and Security

Authentication Control: Manage authentication processes.
Third-Party Integrations: Control and integrate with third-party partner APIs.
Developer Interface: Provides a comprehensive interface for developers.

Developer Support

All APIs are well-documented and available through the Zscaler Help Portal for easy reference and implementation.

Step Up Authentication

Step-up authentication allows dynamic requests for stronger authentication when users attempt to access sensitive resources or when risk signals indicate a potential threat. This feature enhances the existing authentication process by requiring multi-factor authentication (MFA) when needed, ensuring that access to high-risk or sensitive data is protected. Step-up authentication is a method that prompts users to reauthenticate with a higher assurance level (e.g., using MFA) when accessing specific resources. This

Zscaler, Inc. (HQ)
120 Holger Way
San Jose, CA 95134
+1 408.533.0288
zscaler.com

process helps organizations verify user identity with greater certainty, ensuring that only authorized users can access sensitive applications or data. For example, if a user logs in with a username and password (a lower assurance level), they might still be asked to verify their identity via MFA (a higher assurance level) when accessing a sensitive resource, such as financial information or critical applications.

Step-up authentication in ZIdentity enables organizations to:

- Enhance Security: Protect sensitive resources by requiring stronger authentication methods when necessary.
- Provide Dynamic Risk-Based Access: Automatically adjust the level of authentication required based on user behavior or risk signals.
- Simplify Compliance: Meet regulatory requirements by ensuring high-assurance authentication for critical data access.

How Does Step-Up Authentication Work

Step-up authentication is configured using authentication levels (e.g., AL1 to AL4), representing increasing authentication strength. These levels are hierarchical, where higher levels provide stronger assurance.

User Attempts Access
The user logs in to ZIdentity with standard credentials (e.g., username and password).

Accessing a Sensitive Resource
When the user attempts to access a high-sensitivity resource (as defined by policies in ZIA or ZPA), ZIdentity checks the required authentication level.

Step-Up Triggered
If the user's current authentication level is insufficient (e.g., they logged in with a basic password), ZIdentity prompts the user to reauthenticate, typically using MFA via Zscaler Client Connector.

Access Granted
After the user successfully authenticates with the required level, access is granted.

Rate Limiting

- Every endpoint and action have two of rate limit types:
- A lower bound limit that protects against high bursts of requests over a short period of time
- An upper bound limit that protects against a high volume of requests over a long period of time

These limits throttle the number of API calls you can make. Every endpoint has a weight, and every weight has a default rate limit, but some endpoints have exceptions.

Best Practices

Secure API Usage

- Rotate API tokens using ZIdentity periodically to prevent unauthorized access.
- Always generate different Access Tokens for separate endpoints.

Zscaler, Inc. (HQ)
120 Holger Way
San Jose, CA 95134
+1 408.533.0288
zscaler.com

- Always validate and assign the specific API resources to the users, e.g. Do not provide the super admin access to everyone.
- Never share the Secret ID/JWT or Client ID to anyone.
- Always use HTTPS for secure communication.

Maintaining Consistency

- Always use Zscaler provided JSON templates for all Zscaler APIs for standardizing configurations.
- Implement version control for all Zscaler API scripts.

Enhancing Scalability

- Use batch requests for bulk operations.
- Monitor OneAPI usage via Postman REST API client to avoid exceeding rate limits.
- Deployment Methodologies
- Always test changes in staging before production.
- Use environment variables for sensitive information like OneAPI tokens using ZIdentity.

Error Codes

Make sure there is no error in the configuration of your request. Look for typos, whitespaces, or invalid JSON formatting.

Compare the API documentation of the service you're making a call to with the configuration of your request. Check that the elements below are configured correctly in the request:

- The request headers
- The parameters in the request body
- The query parameters
- The HTTP method

Experience your world, secured.

Zscaler, Inc. (HQ)
120 Holger Way
San Jose, CA 95134
+1 408.533.0288
zscaler.com